

Tracking MintsLoader Infrastructure and Validating IOC Provenance in Italian Campaigns

CS4 technical case study

BresshSec

Independent Cybersecurity & Threat Research

Public evidence review through 30 September 2026

Prepared for CERT review, editorial publication, and public repository release

Main conclusion: the June 2026 GhostWallet chain is technically consistent with MintsLoader, but public artifacts do not support definitive attribution. The strongest finding is the provenance review of the Pester image URL, which has documented legitimate historical use and should be treated as likely noise unless campaign telemetry shows otherwise.

Finding	Assessment	Publication position
June GhostWallet link	Moderate confidence	Technically consistent with MintsLoader; definitive attribution remains open
Shared 165.22.13.227	Confirmed overlap	Supports correlation; does not prove common control
Pester image URL	Likely noise	Exclude from attacker infrastructure unless campaign telemetry supports it
x3qqyj78o2rdso9.top	Unverified	Keep outside the confirmed dataset pending reproducible evidence

Evidence classes used in this paper: confirmed evidence, analytical correlation, and hypothesis.

Confidence labels describe the public evidence available, not the underlying truth of unavailable private telemetry.

Abstract

This case study examines two questions raised by public reporting on Italian malware activity in 2026. First, it tests whether the delivery chain documented in Certego's Operation GhostWallet can be retrospectively associated with MintsLoader. Second, it evaluates the provenance of indicators published for the 24 September 2026 CERT-AGID MintsLoader campaign.

The June intrusion reproduces several documented MintsLoader traits: a Fattura JavaScript lure, hidden PowerShell execution, an initial `1.php?s=` request, a later 15-character `.top` domain, and delivery of a secondary payload. These traits support a meaningful correlation. They do not close the attribution because the body returned by the remote endpoint is unavailable and no public sandbox report identifies the specific June loader as MintsLoader. We therefore assess the relationship with moderate confidence.

The IOC provenance review produces a stronger result. The URL `pesterbdd.com/images/Pester.png`, included in the September CERT-AGID export, is present in historical Pester module metadata from at least 2015 and was independently recovered from PowerShell memory in a 2022 sandbox report, where it appeared beside other Pester metadata. Its presence is best explained as package metadata or environmental residue unless campaign-specific network evidence shows otherwise. This demonstrates why IOC publication benefits from distinguishing contacted infrastructure from strings extracted from files, memory, dependencies, and analysis environments.

Key findings

1. The public GhostWallet evidence is consistent with MintsLoader delivery, but it does not support a definitive attribution. Confidence is moderate.
2. The overlap at `165.22.13.227` is confirmed between Certego's June report and the September CERT-AGID JSON. Shared infrastructure strengthens the correlation but cannot, by itself, establish continuity of control.
3. `pesterbdd.com/images/Pester.png` has documented legitimate provenance as the historical icon URL of the Pester PowerShell module. It should be reviewed as likely noise and excluded from attacker infrastructure lists unless supported by campaign-specific telemetry.
4. `x3qqyj78o2rds09.top` is absent from the public CERT-AGID JSON examined. Public indexed searches did not produce a reliable independent record, so novelty and campaign membership remain unverified.

Scope and evidence standard

The study uses public primary reports, vendor technical analysis, official package records, and public sandbox output. It separates three evidence classes:

- Confirmed evidence is directly stated or observable in a cited source.
- High-confidence correlation requires multiple independent observations with specific overlap and no material contradiction.
- Hypothesis describes a technically plausible relationship that lacks the artifact or telemetry needed to close the claim.

Absence from search results is never treated as proof of global absence. A public IOC export is treated as a bounded snapshot, not a complete representation of private or later-updated feeds.

Operation GhostWallet in June 2026

Certego reports that the incident began on 9 June 2026 with `Fattura130334551.js`. The JavaScript created a PowerShell file and launched it through WMI with a hidden window. The decoded command used `Invoke-RestMethod` and `Invoke-Expression` to retrieve content from `waltagemusic.com/1.php?s=<UUIDv4>`. Telemetry then recorded `uk07m7j6xy80p1i.top` and `165.22.13.227`, runtime C# compilation, and the staging of a trojanized Exodus package containing a custom Rust RAT.

Certego also records the material limitation: the initial JavaScript and the complete HTTP body returned by `waltagemusic.com` were not available for offline analysis. The report reconstructs the behavior from endpoint telemetry, but it does not name the delivery component MintsLoader.

Comparison with independently documented MintsLoader tradecraft

Red Canary describes MintsLoader as a multi-stage PowerShell loader that commonly begins with JavaScript and uses a URL containing `1.php?s=`. Its reporting includes Italian invoice lures named `Fattura` followed by digits, `.top` domains generated by a DGA, host fingerprinting, and subsequent requests containing `id`, `key`, and `s` parameters.

eSentire independently documents spam-delivered JavaScript matching `Fattura[0-9]{8}.js`, PowerShell execution, a response containing further obfuscated PowerShell, anti-virtualization checks, and generation of a 15-character `.top` domain. These characteristics closely match the observable structure of the June chain.

The match is specific enough to rule out a merely generic JavaScript-to-PowerShell resemblance. The invoice filename, `1.php?s=` endpoint, 15-character `.top` stage, and secondary-payload role form a recognizable combination. The evidence still lacks the decisive artifact: the content served to the June victim. Without that content, a signature match, code overlap, or a sandbox family verdict tied to the exact sample cannot be reproduced.

Publication verdict for June

The appropriate wording is:

The June 2026 GhostWallet delivery chain is technically consistent with MintsLoader tradecraft. The available public evidence does not preserve the remote stage required for a definitive family attribution, so we assess the relationship with moderate confidence.

The study should not say that GhostWallet was MintsLoader, that the same operator controlled both campaigns, or that infrastructure reuse proves campaign continuity.

Infrastructure overlap with the September campaign

The CERT-AGID JSON for the 24 September campaign explicitly labels the event MintsLoader and lists `165.22.13.227`. Certego's June report lists the same address in association with `uk07m7j6xy80p1i.top`. This overlap is confirmed.

The evidentiary meaning is narrower than attribution. Hosting addresses may be reused, reassigned, shared, or retained by infrastructure providers. The overlap increases the probability that the campaigns

used related delivery infrastructure, especially when considered with the matching tradecraft. It does not establish a common operator without registration history, passive DNS, server-side data, or repeated sample-level configuration.

Provenance analysis of the Pester URL

The September CERT-AGID JSON includes both `pesterbdd.com` and `http://pesterbdd.com/images/Pester.png`. Three historical records explain why this entry requires review.

First, the PowerShell Gallery manifest for Pester 3.3.5 contains the exact URL as `IconUri`. Second, Chocolatey's Pester 3.3.12 package, updated on 8 December 2015, exposes the same icon URL. Third, a Joe Sandbox report started on 1 December 2022 recovered the URL from PowerShell memory beside `github.com/Pester/Pester`, the Apache license URL, and other package metadata. That report marked the URL safe at the time.

PowerShell Gallery and Chocolatey are separate distribution records but derive their metadata from the same software project. Joe Sandbox provides an independent observation in a different execution context. Together, the sources establish legitimate historical provenance. They do not prove that the domain can never be compromised or abused.

Publication verdict for Pester

Classify the URL as `excluded-or-noisy` with high confidence and state that campaign-specific network telemetry could change the assessment. Avoid saying that CERT-AGID made an error. The defensible finding is that the published entry lacks enough provenance context to function safely as an attacker-infrastructure indicator.

Review of `x3qqyj78o2rdso9` top

The domain does not appear in the public CERT-AGID JSON snapshot examined. Exact-string searches across publicly indexed CERT pages, abuse feeds, code repositories, sandbox pages, and threat-intelligence portals did not return a reliable record that could be cited and reproduced.

This result is negative evidence with limited scope. Search indexing is incomplete, feeds change, private submissions are invisible, and some services require authenticated API access. The domain therefore remains a candidate indicator. It should not be described as newly discovered, independently confirmed, or absent from all public feeds until a sample, network trace, or reproducible sandbox report is preserved.

Implications for IOC production

An IOC list should preserve how each value was observed. At minimum, producers should distinguish:

- contacted network destinations;
- DNS resolutions observed during execution;
- strings extracted from files or memory;
- package and dependency metadata;
- sandbox environment artifacts;
- analyst-enriched relationships.

The Pester case shows the operational consequence of flattening these categories. A legitimate metadata URL can acquire the appearance of attacker infrastructure when extraction context is discarded. Consumers may then block a benign resource, propagate the entry to other feeds, or infer relationships that the original telemetry never established.

Detection guidance

Defenders should prioritize behavioral combinations over isolated domains. Useful signals include execution of invoice-themed JavaScript by `wscript.exe`, creation of a PowerShell file followed by hidden execution, use of `Invoke-RestMethod` or `curl` together with `Invoke-Expression`, requests to `1.php?s=`, and later requests to algorithmically named `.top` domains with `id`, `key`, and `s` parameters.

Individual signals can be legitimate. Detection logic should join process ancestry, command-line content, network destination characteristics, and short time windows. Domains and IP addresses remain useful for immediate containment, but behavior survives infrastructure rotation.

Limitations

The June remote stage was not recovered from the public record. No server-side evidence or passive-DNS dataset was available to establish ownership continuity. Public search cannot establish global absence from feeds. The Pester assessment addresses provenance, not the current security state of the domain. Later telemetry showing campaign-specific contact or malicious content would require reassessment.

Conclusion

The strongest conclusion is methodological and operational. The GhostWallet chain deserves a documented MintsLoader correlation, with moderate confidence and an explicit artifact gap. The Pester URL should be separated from attacker infrastructure because historical evidence provides a plausible, well-supported benign origin. The candidate `x3qqyj78o2rds09.top` should remain outside the confirmed dataset until its observation can be reproduced.

This calibrated treatment makes the case study suitable for CERT review, editorial publication, and a public GitHub repository. It preserves the useful relationship without overstating attribution and turns a noisy IOC into a reproducible example of provenance analysis.

References

1. Certego, "PEC malevola e crypto wallet," 22 July 2026. <https://www.certego.net/it/blog/pec-malevola-e-crypto-wallet-trojan-di-accesso-remoto/>
2. CERT-AGID, "MintsLoader via PEC: falsi solleciti di pagamento per diffondere malware," 24 September 2026. <https://cert-agid.gov.it/news/mintsloader-via-pec-falsi-solleciti-di-pagamento-per-diffondere-malware/>
3. CERT-AGID, public IOC JSON for event 26383. <https://cert-agid.gov.it/wp-content/uploads/2026/09/mintsloader-pec-24-09-2026.json>
4. Red Canary, "MintsLoader," Threat Detection Report. <https://redcanary.com/threat-detection-report/threats/mintsloader/>
5. eSentire Threat Response Unit, "MintsLoader: StealC and BOINC Delivery," 16 January 2025. <https://www.esentire.com/blog/mintsloader-stealc-and-boinc-delivery>
6. PowerShell Gallery, Pester 3.3.5 manifest. <https://www.powershellgallery.com/packages/Pester/3.3.5/Content/Pester.psd1>
7. Chocolatey Community Repository, Pester 3.3.12. <https://community.chocolatey.org/packages/pester/3.3.12>
8. Joe Sandbox, analysis 758249, started 1 December 2022. <https://www.joesandbox.com/analysis/758249/0/pdf>
9. ANY.RUN, historical analysis of the Pester image URL. <https://any.run/report/52f47b2ffb1dbb5da4239354d04044edf7b0d912b1fb26225479b418fcebe419/c6807ec4-4d45-4823-81ca-9e27529e1ad6>